

ĐHQG-HCM – TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN

Hệ điều hành Linux & Ứng dụng

ĐỒ ÁN CUỐI KỲ

Yêu cầu, Hướng dẫn & Thang điểm

Học phần	Module 5 — Scripting & Đồ án cuối kỳ
Buổi học	Buổi 11 (xây dựng + demo trực tiếp + vấn đáp)
Trọng số	20% điểm tổng kết học phần
Thang điểm	10 điểm + 1 điểm thưởng (TLS tự ký)
Môi trường	VirtualBox hoặc VMware · Ubuntu 22.04 Server hoặc CentOS Stream 9
Hình thức	Nhóm 5 sinh viên (xem §2)
Đánh giá	Demo trực tiếp + báo cáo kỹ thuật + vấn đáp

Không cần tài khoản cloud. Toàn bộ đồ án chạy trên máy ảo cục bộ.

1. Tổng quan đồ án

Đồ án cuối kỳ là bài đánh giá tổng kết của học phần. Nhóm cần kết hợp toàn bộ kiến thức từ Module 1–5 — dòng lệnh, quản trị hệ thống, lưu trữ, mạng, gia cố bảo mật, triển khai dịch vụ và tự động hóa bằng Bash — thành một hệ thống Linux hoàn chỉnh, hoạt động thực sự, do nhóm tự xây dựng, bảo mật, tự động hóa, viết tài liệu và bảo vệ.

Đây không phải bài thi viết. Điểm được chấm trên một hệ thống chạy thật. Trong buổi demo, nhóm sẽ khởi động máy ảo, trình diễn các dịch vụ trực tiếp, chủ động gây lỗi và chứng minh phần tự động hóa cùng cơ chế sao lưu khôi phục được hệ thống. Sau đó nhóm trả lời các câu hỏi kỹ thuật về những quyết định đã đưa ra.

1.1 Chuẩn đầu ra được đánh giá

Hoàn thành đồ án, sinh viên chứng minh được khả năng:

- Cài đặt và cấu hình một máy chủ Ubuntu hoặc CentOS từ bản cài sạch.
- Triển khai và kết nối các dịch vụ thực (web server, cơ sở dữ liệu, và/hoặc một ứng dụng) sao cho chúng phối hợp hoạt động đầu-cuối.
- Gia cố hệ thống đến một mức nền có thể bảo vệ được: tường lửa, chính sách SSH, chống dò mật khẩu và ghi log kiểm toán.
- Thiết kế và hiện thực quy trình sao lưu — khôi phục hoạt động được, và chứng minh khôi phục trực tiếp.
- Tự động hóa các tác vụ vận hành bằng Bash — giám sát, sao lưu, cảnh báo, triển khai — kèm xử lý lỗi đúng cách.
- Viết tài liệu hệ thống đạt chuẩn chuyên nghiệp và bảo vệ được các quyết định kỹ thuật khi được hỏi.

1.2 Cách đọc tài liệu này

Mục 2 là quy định chung. Mục 3 là phần nền tảng bắt buộc. Mục 4–6 mô tả một dự án hợp nhất duy nhất gồm ba thành phần bắt buộc: (4) Hạ tầng, Web & Bảo mật, (5) Ứng dụng & CSDL, (6) Vận hành & Tự động hóa — nhóm phải làm cả ba, không chọn lựa. Mục 7 nói về điểm thưởng TLS (tùy chọn). Mục 8–10 định nghĩa ba sản phẩm nộp (báo cáo, demo, vấn đáp). Mục 11 là thang điểm chi tiết. Mục 12 là bảng kiểm yêu cầu để rà soát trong lúc làm, và Mục 13 là bảng kiểm cuối cùng trước buổi demo.

2. Quy định chung

2.1 Môi trường

Trình ảo hóa: Oracle VirtualBox hoặc VMware Workstation/Player (chọn một; ghi lại trong báo cáo).

Hệ điều hành khách: Ubuntu 22.04 LTS Server HOẶC CentOS Stream 9 (bản không giao diện đồ họa). Chọn một và dùng nhất quán.

Cấu hình VM: Tối thiểu 2 vCPU, 2 GB RAM, 20 GB đĩa mỗi VM. Giữ gọn nhẹ — các bài lab được thiết kế cho máy phòng thực hành cấu hình thấp.

Mạng: Host-Only hoặc Internal network là đủ (tên gọi tương đương trên VMware là Host-only / LAN Segment). Cho phép NAT để cài gói. Ghi lại chế độ adapter đã chọn trong báo cáo.

Số lượng VM: Nhóm 5 người BẮT BUỘC dùng ít nhất 2 VM — một máy dịch vụ chính và một máy dùng cho sao lưu/nhân bản hoặc truy cập từ xa (ví dụ qua SSH ProxyJump).

Công cụ theo distro: Yêu cầu không phụ thuộc distro. Dùng bộ công cụ khớp với HĐH: apt / UFW / /etc/ssl trên Ubuntu, hoặc dnf / firewallld / /etc/pki/tls trên CentOS. Nên lựa chọn trong báo cáo; cả hai được chấm ngang nhau.

2.2 Quy mô nhóm & phân công

Mỗi nhóm gồm 5 sinh viên. Vì là nhóm lớn, kỳ vọng về độ sâu vận hành cao hơn hẳn so với làm cá nhân: hệ thống nhiều VM, bộ script tự động hóa phong phú, và bảo mật/sao lưu được hiện thực đầy đủ. Yêu cầu cụ thể với nhóm 5 người:

- Bắt buộc kiến trúc từ 2 VM trở lên (xem §2.1).
- Có bảng phân công công việc trong báo cáo, ánh xạ 5 thành viên lên ba thành phần của dự án (Mục 4–6). Gợi ý 5 vai: (1) hạ tầng & mạng, (2) reverse proxy & bảo mật web, (3) ứng dụng & systemd, (4) CSDL & sao lưu, (5) bộ công cụ tự động hóa & cảnh báo.
- Điểm chấm theo cá nhân trên nền điểm nhóm: mỗi thành viên phải bảo vệ được phần mình phụ trách VÀ hiểu tổng thể hệ thống. Thành viên không giải thích được phần của mình sẽ bị trừ điểm cá nhân dù hệ thống chạy tốt.
- Trong buổi vấn đáp, giảng viên có thể hỏi bất kỳ thành viên nào về bất kỳ thành phần nào của hệ thống.

Phân công không có nghĩa là “mạnh ai nấy làm”

Cả nhóm chịu trách nhiệm cho toàn bộ hệ thống. Việc chia phần chỉ để rõ ràng trách nhiệm — mọi thành viên vẫn phải nắm được cách các thành phần ghép nối với nhau. Một hệ thống rời rạc, các thành viên không hiểu phần của nhau, sẽ bị đánh giá thấp ở tiêu chí Báo cáo & vấn đáp.

2.3 Tiến độ

Thời điểm	Nội dung
Buổi 10	Chốt hướng đồ án và danh sách nhóm 5 người. Bắt đầu xây dựng — nền tảng Bash scripting đã học ở buổi này.
Trước buổi 11	Hoàn tất xây dựng. Viết báo cáo kỹ thuật. Tạo snapshot trạng thái sạch, hoạt động tốt để phòng khi demo gặp sự cố có thể khôi phục.
Buổi 11 (tại lớp)	Demo trực tiếp (≈12–15 phút) + vấn đáp (≈8–10 phút) cho mỗi nhóm.
Hạn nộp	Nộp báo cáo + toàn bộ script/cấu hình dưới dạng một file nén, trước khi kết thúc buổi 11 (giờ cụ thể thông báo tại lớp).

2.4 Sản phẩm nộp

Một file nén đặt tên theo mẫu

capstone_<MãNhóm>.tar.gz	# ví dụ: capstone_N05.tar.gz
--------------------------	------------------------------

bao gồm:

- Báo cáo kỹ thuật (PDF).
- Toàn bộ script Bash nhóm viết, giữ nguyên shebang và chú thích.
- Toàn bộ file cấu hình dịch vụ đã chỉnh (Nginx/Apache, systemd unit, cấu hình CSDL, luật UFW/firewalld, fail2ban, auditd) — file thật, không phải ảnh chụp.
- Một file README.md nêu: hướng đồ án đã chọn, sơ đồ VM, bảng phân công thành viên, và cách tái tạo hệ thống.

Tuyệt đối không nộp thông tin bí mật

Không bao giờ đưa mật khẩu thật, khóa riêng, hay API token vào file nộp. Thay bằng placeholder (ví dụ <DB_PASSWORD>) và giải thích trong báo cáo nơi lưu trữ bí mật trên hệ thống đang chạy. Để lộ bí mật thật là lỗi bị trừ điểm ngay ở tiêu chí Bảo mật.

3. Nền tảng bắt buộc

Hệ thống của nhóm phải thỏa toàn bộ các yêu cầu sau. Đây là phần lõi không thể bỏ qua, tương ứng trực tiếp với các tiêu chí Bảo mật, Sao lưu và Tự động hóa trong thang điểm, và làm nền cho ba thành phần ở Mục 4–6.

3.1 Hệ thống & lưu trữ

- Cài Ubuntu 22.04 Server hoặc CentOS Stream 9 bản sạch, đặt hostname có ý nghĩa (không để mặc định).
- Có tài khoản quản trị non-root với sudo; công việc hằng ngày làm bằng tài khoản đó, không dùng root.
- Có ít nhất một vùng dữ liệu/sao lưu riêng, mount qua /etc/fstab và tồn tại sau khi khởi động lại. Khuyến khích dùng LVM (đã thực hành mở rộng online ở Module 2), nhưng một phân vùng hay đĩa ảo riêng cũng được chấp nhận.

3.2 Gia cố bảo mật (ứng với tiêu chí Bảo mật 20%)

- Tường lửa (UFW trên Ubuntu hoặc firewalld trên CentOS) bật ở chế độ mặc định chặn chiều vào; chỉ mở đúng các cổng dịch vụ cần dùng. Giải thích lý do mở từng cổng trong báo cáo.
- Gia cố SSH trong sshd_config: tắt đăng nhập root, cấu hình xác thực bằng khóa, và tối thiểu một trong hai {đổi cổng khác mặc định, giới hạn AllowUsers}. Có thể để đăng nhập bằng mật khẩu phục vụ demo nhưng báo cáo phải nêu rõ đánh đổi.
- Cài fail2ban bảo vệ SSH. Phải trình diễn được một lần ban trực tiếp (hoặc cho xem một ban gần đây trong trạng thái jail) khi demo.
- Cài auditd (hoặc tương đương) theo dõi ít nhất hai tệp nhạy cảm /etc/passwd và /etc/shadow, với dấu vết kiểm toán đọc được.
- Ghi lại một lần chạy Lynis trong báo cáo với điểm gia cố và ít nhất ba mục đã khắc phục (như đã thực hành ở buổi 6).

3.3 Sao lưu & khôi phục (ứng với tiêu chí Sao lưu 20%)

- Sao lưu tự động dữ liệu quan trọng của hệ thống (dump CSDL và/hoặc file ứng dụng và/hoặc nội dung web), có nén và gắn nhãn thời gian.
- Chính sách lưu giữ (retention) tự động xóa bản sao lưu cũ hơn một mốc đã nêu (ví dụ 7 ngày), hiện thực trong script — không làm thủ công.
- Lịch chạy sao lưu bằng cron hoặc systemd timer, có ghi lại lịch trong báo cáo.
- Có quy trình khôi phục chạy được trực tiếp. Khi demo, nhóm sẽ hủy hoặc làm hỏng dữ liệu đang chạy rồi khôi phục từ bản sao lưu, và chứng minh dữ liệu còn nguyên vẹn.

Khôi phục mới là điểm mấu chốt

Một bản sao lưu chưa từng thử khôi phục thì chưa phải là sao lưu. 20% của tiêu chí này chỉ đạt được khi có một lần khôi phục trực tiếp thấy rõ dữ liệu được phục hồi — không phải chỉ cho xem file sao lưu tồn tại. Hãy luyện tập trước.

3.4 Tự động hóa (ứng với tiêu chí Tự động hóa 15%)

- Ít nhất một script health-check kiểm tra trạng thái thực của hệ thống (dịch vụ còn chạy không, cổng có lắng nghe không, ngưỡng disk/CPU/RAM) và phản ứng — ghi log và/hoặc cảnh báo — khi có bất thường.
- Script dùng set -euo pipefail và trap trên ERR/EXIT để bắt lỗi thay vì bỏ qua thầm lặng (kiến thức buổi 10).
- Mọi script vượt qua shellcheck không còn lỗi. Kèm output shellcheck sạch hoặc nêu các cảnh báo còn lại có lý do trong báo cáo.
- Cảnh báo hiện thực qua ít nhất một kênh: lệnh mail, email msmtplib, hoặc Telegram Bot API qua curl. Một lỗi mô phỏng phải thực sự kích hoạt cảnh báo khi demo.

4. Dự án hợp nhất — Kiến trúc & Thành phần 1: Hạ tầng, Web & Bảo mật

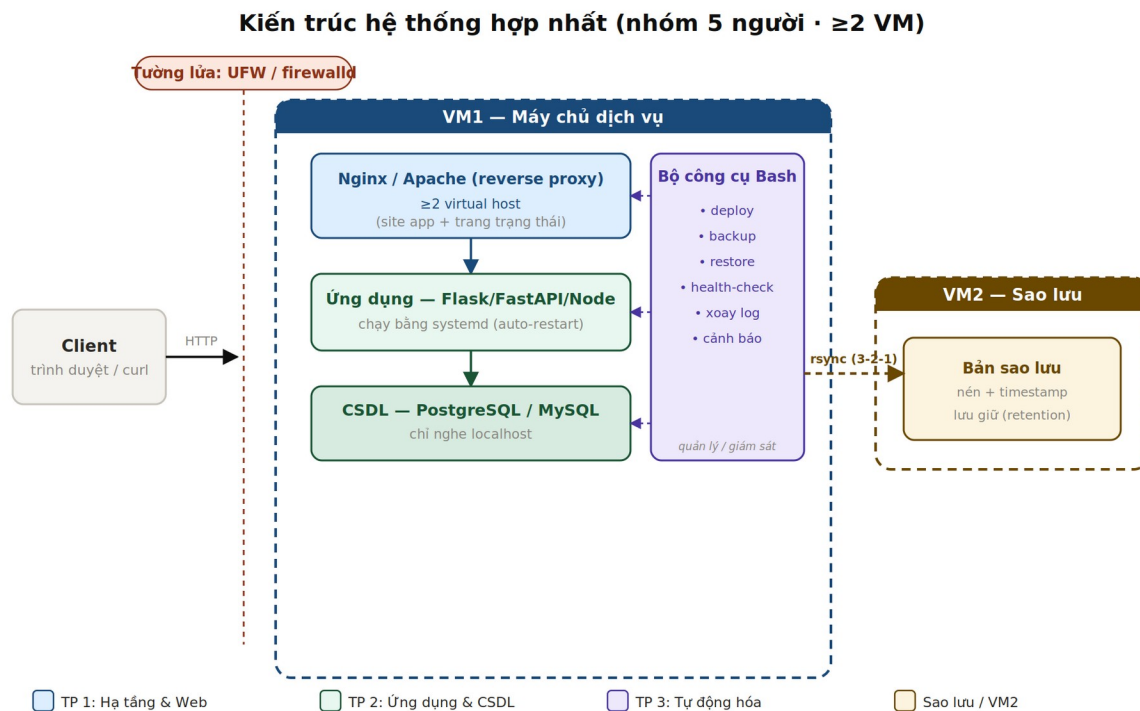
Toàn bộ đồ án là MỘT hệ thống duy nhất

Nhóm 5 người xây dựng một hệ thống hợp nhất gồm ba thành phần bắt buộc: (1) Hạ tầng, Web & Bảo mật — Mục 4; (2) Ứng dụng & CSDL — Mục 5; (3) Vận hành & Tự động hóa — Mục 6. Không chọn lựa: cả ba đều phải làm và phải phối hợp hoạt động với nhau.

4.1 Kiến trúc tổng thể

Luồng xử lý xuyên suốt hệ thống: trình duyệt/curl → Nginx/Apache (reverse proxy, có ≥ 2 virtual host) → ứng dụng chạy bằng systemd (Mục 5) → CSDL quan hệ chỉ nghe trên localhost. Toàn bộ vận hành — triển khai, sao lưu, giám sát — đi qua bộ công cụ Bash (Mục 6). Hệ thống trải trên ít nhất 2 VM: một máy dịch vụ chính và một máy nhận bản sao lưu/nhân bản.

Ba thành phần dưới đây ánh xạ trực tiếp lên các tiêu chí chấm điểm: Thành phần 1 hội tụ phần Bảo mật, Thành phần 2 là phần lõi "Hệ thống chạy được", Thành phần 3 gánh phần Sao lưu và Tự động hóa.



Hình 1 — Sơ đồ kiến trúc hệ thống hợp nhất và ba thành phần bắt buộc.

4.2 Yêu cầu — Hạ tầng, Web & Bảo mật

- Nginx hoặc Apache làm reverse proxy đứng trước ứng dụng ở Mục 5 (proxy_pass của Nginx, hoặc mod_proxy/ProxyPass của Apache, trở tới cổng cục bộ của app), chuyển tiếp đúng các header.
- Ngoài site ứng dụng, phục vụ thêm ít nhất một virtual host nữa (ví dụ trang trạng thái tĩnh hoặc site thứ hai) → tổng cộng ≥ 2 virtual host trên cùng một web server (Nginx hoặc Apache).
- Gia cố hệ thống đầy đủ theo §3.2 (tường lửa = UFW hoặc firewalld tùy distro) — đây là nơi tiêu chí Bảo mật hội tụ.
- Khuyến khích cho fail2ban bảo vệ cả tầng web nếu ứng dụng có endpoint dạng đăng nhập.
- Kiến trúc từ 2 VM trở lên, có sơ đồ kết nối trong báo cáo; nếu dùng VM thứ hai làm bastion, cấu hình SSH ProxyJump (kiến trúc buổi 5).

4.3 Demo phải trình diễn (phần này)

- Cả hai virtual host phản hồi, ví dụ qua curl -H "Host: ..." từ máy host hoặc VM thứ hai.
- Một lần ban fail2ban trực tiếp sau khi mô phỏng dò mật khẩu SSH.
- auditd bắt được truy cập vào /etc/passwd hoặc /etc/shadow.

5. Thành phần 2: Ứng dụng & Cơ sở dữ liệu

Tóm tắt

Một ứng dụng Python (Flask/FastAPI) hoặc Node.js thật, dùng CSDL quan hệ (PostgreSQL hoặc MySQL), chạy như dịch vụ systemd và được web server ở Mục 4 (Nginx hoặc Apache) proxy tới. Đây là phần lõi "Hệ thống chạy được".

5.1 Yêu cầu — Ứng dụng & CSDL

- Một ứng dụng chạy được (Flask, FastAPI, hoặc Node.js/Express). Có thể nhỏ, nhưng phải giao tiếp với CSDL và có ít nhất một endpoint đọc và một endpoint ghi.
- Một CSDL quan hệ — PostgreSQL hoặc MySQL: tạo CSDL riêng và một user/role ứng dụng chỉ với quyền cần thiết (nguyên tắc đặc quyền tối thiểu), không dùng tài khoản quản trị của CSDL cho ứng dụng.
- CSDL chỉ nghe trên localhost (bind-address với MySQL, hoặc listen_addresses/pg_hba với PostgreSQL) — không truy cập được từ bên ngoài máy. Chứng minh bằng ss khi demo.
- Ứng dụng chạy như một dịch vụ systemd: có .service unit với Restart=on-failure, một EnvironmentFile cho bí mật (chuỗi kết nối/thông tin CSDL), và log đẩy về journald qua stdout/stderr.
- Bí mật để ngoài mã nguồn — trong EnvironmentFile với quyền hạn chế — không hard-code. Báo cáo phải cho thấy quyền của file đó.
- Sao lưu CSDL (mysqldump hoặc pg_dump) do bộ công cụ ở Mục 6 đảm nhận, theo phần nền tảng §3.3.

5.2 Demo phải trình diễn (phần này)

- Ứng dụng phục vụ đầu-cuối qua web server (trình duyệt hoặc curl → Nginx/Apache → app → CSDL → phản hồi).
- systemctl status cho thấy ứng dụng là dịch vụ active và enabled.
- Mô phỏng sập (kill tiến trình ứng dụng) và systemd tự khởi động lại, với sự kiện thấy được trong journalctl.
- Output ss chứng minh CSDL chỉ nghe trên 127.0.0.1.

6. Thành phần 3: Vận hành & Tự động hóa

Tóm tắt

Một bộ công cụ Bash theo dạng menu điều khiển toàn bộ vòng đời vận hành của hệ thống trên: triển khai, sao lưu & khôi phục, health-check, và xoay vòng log. Đây là nơi hội tụ tiêu chí Sao lưu và Tự động hóa.

6.1 Yêu cầu — Bộ công cụ Bash

- Một menu CLI tương tác (điểm vào) điều phối tới từng công cụ và xử lý nhập sai một cách nhẹ nhàng.
- Chức năng triển khai (deploy): đưa app/site vào đúng chỗ, đặt quyền sở hữu và phân quyền đúng, rồi (khởi động lại) dịch vụ an toàn (test → reload → xác nhận, có rollback nếu reload lỗi).

- Chức năng sao lưu (backup): dump CSDL (Mục 5) + nội dung web (Mục 4), nén, gắn nhãn thời gian, lưu giữ, và rsync sang VM thứ hai (ý tưởng 3-2-1 từ buổi 10).
- Chức năng khôi phục (restore): phục hồi CSDL/nội dung từ một bản sao lưu do chính bộ công cụ tạo ra.
- Chức năng health-check: CPU, disk, RAM, cổng lắng nghe, và trạng thái dịch vụ (web server, app, CSDL) so với ngưỡng cấu hình được, kèm cảnh báo khi vượt ngưỡng.
- Chức năng xoay vòng log: xoay và nén một log đã chọn, giữ N thế hệ, xóa thế hệ cũ hơn.
- Mỗi công cụ: tham số kiểu getopt khi hợp lý, set -euo pipefail, trap trên ERR, ghi log rõ đã làm gì, và có output --help. Toàn bộ vượt qua shellcheck sạch sẽ.

6.2 Demo phải trình diễn (phần này)

- Menu chạy và điều phối tới từng công cụ.
- Một lần deploy có kèm cấu hình cố tình lỗi, cơ chế reload an toàn bắt được lỗi, và tự động rollback về trạng thái tốt gần nhất.
- Một lần backup tạo file nén gắn nhãn thời gian và rsync sang VM thứ hai, cộng bước lưu giữ xóa một bản cũ.
- Hủy dữ liệu đang chạy rồi khôi phục trực tiếp từ bản sao lưu do bộ công cụ tạo ra, chứng minh toàn vẹn.
- Một lần vượt ngưỡng health-check (ví dụ dừng một dịch vụ) kích hoạt cảnh báo.
- Chạy shellcheck trực tiếp trên bộ công cụ với kết quả sạch.

7. TLS / HTTPS — Điểm thưởng tùy chọn (+1 điểm)

SSL/TLS không bắt buộc cho điểm nền. Hệ thống được chấm trên HTTP. Tuy nhiên, triển khai đúng một chứng chỉ TLS tự ký hoạt động được sẽ được cộng 1 điểm thưởng trên thang 10 điểm.

7.1 Vì sao dùng tự ký, và vì sao không dùng Let's Encrypt ở đây

Tài liệu buổi 7 dạy certbot / Let's Encrypt, nhưng cách đó không chạy được trên một VM lab cô lập — và hiểu vì sao chính là một phần của yêu cầu:

- Let's Encrypt chỉ cấp chứng chỉ cho một tên miền công khai mà nó xác thực được qua Internet (thử thách ACME truy cập máy chủ của bạn trên cổng 80/443 từ bên ngoài).
- Một VM VirtualBox trên mạng Host-Only hoặc Internal không có tên miền công khai và không tiếp cận được từ máy chủ ACME, nên xác thực tên miền thất bại.
- Vì vậy cách đúng ở môi trường cục bộ là chứng chỉ tự ký (hoặc một CA nội bộ nhỏ do nhóm tự tạo). Báo cáo phải nêu lập luận này để được điểm thưởng — chỉ chạy lệnh là chưa đủ.

7.2 Điều kiện đạt điểm thưởng

- Tạo chứng chỉ và khóa tự ký bằng openssl (hoặc CA nội bộ + chứng chỉ server cho phiên bản mạnh hơn).
- Cấu hình Nginx (hoặc Apache) phục vụ site/app qua HTTPS bằng chứng chỉ đó.
- Chuyển hướng HTTP thường sang HTTPS.
- Mở cổng 443 trên tường lửa (UFW hoặc firewallld) và xác nhận hành vi 80→443.
- Trình diễn endpoint HTTPS trực tiếp (cảnh báo tin cậy của trình duyệt là bình thường với chứng chỉ tự ký; curl -k hoặc import CA của nhóm đều chấp nhận được).
- Giải thích lập luận §7.1 trong báo cáo.

7.3 Điểm khởi đầu

Một chứng chỉ tự ký tối thiểu (chỉnh đường dẫn và subject theo hệ thống của nhóm):

```
# Tạo cặp chứng chỉ + khóa tự ký, hạn 1 năm
sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
  -keyout /etc/ssl/private/lab-selfsigned.key \
  -out /etc/ssl/certs/lab-selfsigned.crt \
  -subj "/C=VN/ST=HCMC/O=HCMUS-Lab/CN=lab.local"

# Khởi server Nginx (cột lỗi)
# listen 443 ssl;
# ssl_certificate /etc/ssl/certs/lab-selfsigned.crt;
# ssl_certificate_key /etc/ssl/private/lab-selfsigned.key;
# Kèm một khối HTTP trả về 301 -> https://$host$request_uri;

# Apache: SSLEngine on; SSLCertificateFile + SSLCertificateKeyFile;
# chuyển hướng HTTP->HTTPS bằng Redirect permanent / hoặc mod_rewrite.

# CentOS Stream 9: dùng /etc/pki/tls/certs và /etc/pki/tls/private,
# mở 443 bằng: sudo firewall-cmd --add-service=https --permanent && sudo firewall-cmd --reload
```

Điểm thưởng tối đa +1 và không làm tổng điểm vượt mức tối đa theo quy chế điểm của chương trình.

8. Sản phẩm 1 — Báo cáo kỹ thuật

Một báo cáo kỹ thuật súc tích, nộp dạng PDF, khoảng 6–12 trang không kể phụ lục. Chất lượng và tính đúng đắn quan trọng hơn nhiều so với độ dài. Cấu trúc gợi ý:

- **Tổng quan hệ thống** — Hướng đã chọn, sơ đồ VM, chế độ mạng, và một sơ đồ hoặc mô tả rõ cách các thành phần kết nối. Kèm bảng phân công 5 thành viên.
- **Các bước xây dựng** — Những quyết định cấu hình then chốt — không phải chép lại mọi lệnh, mà đủ để người đọc tái tạo hệ thống. Tham chiếu tới các file cấu hình thật đã nộp.
- **Bảo mật** — Chính sách tường lửa và lý do mở từng cổng; lựa chọn gia cố SSH và đánh đổi; cấu hình fail2ban và auditd; điểm Lynis và ba mục đã khắc phục.
- **Sao lưu & khôi phục** — Sao lưu cái gì, bằng cách nào, lịch chạy, chính sách lưu giữ, và quy trình khôi phục chính xác — kèm bằng chứng đã kiểm thử.
- **Tự động hóa** — Từng script: mục đích, tham số, xử lý lỗi, cảnh báo. Kèm kết quả shellcheck.
- **TLS (nếu làm điểm thưởng)** — Lập luận §7.1 kèm cấu hình.
- **Nhìn lại** — Cái gì đã hỏng, cái gì sẽ cải thiện, và nhóm học được gì. Phần nhìn lại trung thực được đánh giá cao.

Ảnh chụp là bằng chứng, không phải trang trí

Mọi khẳng định trong phần bảo mật, sao lưu và tự động hóa cần được chứng minh bằng ảnh chụp có chú thích hoặc một file cấu hình thật trong file nộp. "Nó chạy được" mà không có bằng chứng bị coi là chưa trình diễn.

9. Sản phẩm 2 — Demo trực tiếp

Một buổi demo trực tiếp 12–15 phút trên chính máy ảo của nhóm. Đây là khối điểm lớn nhất (tiêu chí "Hệ thống chạy được" 30% cùng phần lớn điểm Sao lưu và Tự động hóa), nên hãy lên kịch bản và tập trước.

Kịch bản gợi ý

1. Khởi động / trình bày hệ thống đang chạy và mở trạng thái tường lửa + dịch vụ (1–2 phút).
2. Trình diễn phần lõi của hướng đã chọn chạy đầu-cuối (2–3 phút).
3. Bảo mật: kích hoạt một lần ban fail2ban; cho thấy auditd bắt được truy cập vào tệp nhạy cảm (2 phút).
4. Sao lưu & khôi phục: hủy dữ liệu đang chạy, khôi phục từ bản sao lưu tự động, chứng minh toàn vẹn (2–3 phút).
5. Tự động hóa: gây một lỗi để script health-check phát hiện và cảnh báo (1–2 phút).
6. Điểm thưởng TLS, nếu có làm (1 phút).

Chụp snapshot trước

Chụp snapshot một trạng thái VM tốt trước khi trình bày. Nếu một bước demo trực tiếp gặp trục trặc, nhóm có thể rollback và tiếp tục thay vì mất cả buổi demo. Một demo được cứu vẫn có điểm; một demo bị treo thì không.

10. Sản phẩm 3 — Vấn đáp (Q&A)

Sau demo, giảng viên sẽ hỏi 3-5 câu kỹ thuật về hệ thống, hỏi bất kỳ thành viên nào trong nhóm. Mục tiêu là xác nhận nhóm hiểu những gì đã xây dựng chứ không chỉ làm theo hướng dẫn. Mỗi thành viên phải sẵn sàng giải thích phần mình phụ trách và nắm được tổng thể. Câu hỏi tiêu biểu:

- Vì sao mở đúng những cổng đó, và kẻ tấn công được lợi gì từ mỗi cổng?
- Trình bày từng bước điều gì xảy ra khi một yêu cầu tới web server (Nginx/Apache) và đi tới ứng dụng/CSDL.
- SSH của nhóm được gia cố ra sao, và mỗi thiết lập cụ thể ngăn chặn điều gì?
- Cho tôi xem bí mật lưu ở đâu và ai đọc được file đó. Vì sao đặt ở đó?
- Sao lưu chạy lúc 2 giờ sáng — nếu lúc đó đĩa đầy thì sao? Script có phát hiện không?
- Hãy khôi phục CSDL này ngay trước mặt tôi từ một bản sao lưu đã tạo trước đó.
- set -euo pipefail thay đổi gì trong script này, và ở đâu nó đã cứu nhóm?
- (TLS) Vì sao không dùng được Let's Encrypt trên VM này, và nhóm đã làm gì thay thế?

11. Thang điểm

Đồ án chiếm 20% điểm học phần, chấm trên thang 10 điểm cộng tối đa +1 thưởng. Năm tiêu chí dưới đây khớp với đề cương học phần. Trong mỗi tiêu chí, điểm chấm theo mức độ (band) mà sản phẩm đạt tới.

Trọng số	Tiêu chí	Bằng chứng
30%	Hệ thống chạy được	Demo trực tiếp — cả ba thành phần chạy đầu-cuối
20%	Bảo mật	UFW/firewalld, gia cố SSH, fail2ban, auditd, Lynis
20%	Sao lưu & khôi phục	Khôi phục trực tiếp phục hồi dữ liệu thật
15%	Tự động hóa	Script chạy, xử lý lỗi, cảnh báo, shellcheck
15%	Báo cáo & vấn đáp	Chất lượng báo cáo + vấn đáp
+1	Điểm thưởng	TLS tự ký hoạt động kèm lập luận đúng (§7)

Phân mức trong mỗi tiêu chí

Mức	Biểu hiện
Điểm tối đa	Chạy sạch và trực tiếp; đúng, an toàn, có lập luận tốt; sinh viên giải thích tự tin.
Gần tối đa	Chạy được với vài thiếu sót nhỏ hoặc một trục trặc nhẹ; phần lớn đúng; giải thích vững.
Một phần	Chạy được một phần hoặc chỉ có ảnh chụp; còn khoảng trống rõ; giải thích lúng túng.
Rất ít / không	Không trình diễn trực tiếp, hòng, chép mà không hiểu, hoặc không giải thích được.

11.1 Các lỗi bị trừ điểm

- Để lộ bí mật thật (mật khẩu/khóa/token) trong file nộp: trừ ở tiêu chí Bảo mật.
- Bản sao lưu không khôi phục được khi demo: không có điểm Sao lưu, dù script sao lưu trông tốt đến đâu.
- Script không qua shellcheck (còn lỗi), hoặc bỏ qua lỗi (thiếu set -e / trap): giảm điểm Tự động hóa.
- Không giải thích được một thành phần khi vấn đáp: thành phần đó tính là "không hiểu" dù nó chạy — trừ điểm cá nhân của thành viên phụ trách.
- Nộp trễ: theo quy định nộp trễ chuẩn của chương trình.

11.2 Liềm chính học thuật

Nhóm được dùng hướng dẫn, tài liệu và trợ lý AI để học và xây dựng — điều này phản ánh thực tế nghề nghiệp. Nhưng hệ thống là của nhóm và mọi thành viên phải hiểu phần mình. Buổi vấn đáp tồn tại chính để kiểm chứng điều đó: phần không giải thích được thì không có điểm, và việc lấy hệ thống của nhóm khác nhận là của mình bị xử lý là gian lận học thuật theo quy định của Khoa.

12. Bảng kiểm yêu cầu

Một ma trận rà soát toàn bộ yêu cầu bắt buộc, ánh xạ tới tiêu chí chấm điểm tương ứng. Đánh dấu từng ô khi hoàn thành. Mọi mục đều bắt buộc (cột "Áp dụng" ghi "Tất cả") vì đồ án là một hệ thống hợp nhất. Đây là bảng kiểm dùng trong lúc làm; §13 là bảng kiểm cuối trước demo.

✓	Yêu cầu	Áp dụng	Tiêu chí
Hệ thống & lưu trữ			
☐	Cài Ubuntu 22.04 hoặc CentOS Stream 9 bản sạch; đặt hostname có ý nghĩa	Tất cả	Hệ thống
☐	Dùng tài khoản quản trị non-root (sudo) cho công việc hằng ngày	Tất cả	Bảo mật
☐	Vùng dữ liệu/sao lưu riêng mount qua /etc/fstab, tồn tại sau reboot	Tất cả	Hệ thống
☐	Kiến trúc từ 2 VM trở lên (bắt buộc với nhóm 5 người)	Tất cả	Hệ thống
Gia cố bảo mật			
☐	Tường lửa (UFW hoặc firewalld) mặc định chặn vào; chỉ mở cổng cần thiết	Tất cả	Bảo mật
☐	Gia cố SSH: tắt root, xác thực khóa, đổi cổng hoặc AllowUsers	Tất cả	Bảo mật
☐	fail2ban bảo vệ SSH; ban được kích hoạt trực tiếp	Tất cả	Bảo mật
☐	auditd theo dõi /etc/passwd và /etc/shadow; dấu vết đọc được	Tất cả	Bảo mật
☐	Ghi lại lần chạy Lynis; nêu điểm; khắc phục 3 mục	Tất cả	Bảo mật
Sao lưu & khôi phục			
☐	Sao lưu tự động: nén, gán nhãn thời gian, có chính sách lưu giữ	Tất cả	Sao lưu
☐	Lập lịch sao lưu bằng cron hoặc systemd timer; ghi lại lịch	Tất cả	Sao lưu
☐	Đã luyện quy trình khôi phục; phục hồi dữ liệu thật trực tiếp	Tất cả	Sao lưu
Tự động hóa			
☐	Script health-check kiểm tra trạng thái thật và phản ứng (log/cảnh báo)	Tất cả	Tự động hóa
☐	Script dùng set -euo pipefail và trap trên ERR/EXIT	Tất cả	Tự động hóa
☐	Mọi script qua shellcheck (sạch, hoặc nêu cảnh báo có lý do)	Tất cả	Tự động hóa
☐	Kênh cảnh báo (mail / msmtpl / Telegram) hoạt động khi mô phỏng lỗi	Tất cả	Tự động hóa
Thành phần 1 — Hạ tầng, Web & Bảo mật (bắt buộc)			
☐	Web server (Nginx/Apache) reverse proxy trước ứng dụng, chuyển tiếp header đúng	Tất cả	Hệ thống
☐	≥2 virtual host trên cùng web server (site app + ít nhất một site nữa)	Tất cả	Hệ thống
☐	Kiến trúc ≥2 VM, có sơ đồ kết nối trong báo cáo	Tất cả	Hệ thống
Thành phần 2 — Ứng dụng & CSDL (bắt buộc)			
☐	Ứng dụng (Flask/FastAPI/Node) có ít nhất một endpoint đọc và một ghi	Tất cả	Hệ thống
☐	CSDL (PostgreSQL hoặc MySQL): role đặc quyền tối thiểu; chỉ nghe localhost (ss)	Tất cả	Bảo mật
☐	App chạy như dịch vụ systemd: Restart=on-failure, EnvironmentFile,	Tất cả	Hệ thống

✓	Yêu cầu	Áp dụng	Tiêu chí
	journald		
☐	Bí mật trong EnvironmentFile với quyền hạn chế (không hard-code)	Tất cả	Bảo mật
☐	Kill tiến trình app → systemd tự khởi động lại (thấy trong journalctl)	Tất cả	Hệ thống
Thành phần 3 — Vận hành & Tự động hóa (bắt buộc)			
☐	Menu CLI tương tác điều phối tới từng công cụ; xử lý nhập sai	Tất cả	Tự động hóa
☐	Deploy có test → reload → xác nhận an toàn và rollback khi lỗi	Tất cả	Tự động hóa
☐	Backup: dump CSDL + web, nén, gắn nhãn, lưu giữ, rsync sang VM thứ hai	Tất cả	Sao lưu
☐	Restore từ bản sao lưu do bộ công cụ tạo, phục hồi dữ liệu thật	Tất cả	Sao lưu
☐	Health-check: CPU/disk/RAM/cổng/dịch vụ so ngưỡng, có cảnh báo	Tất cả	Tự động hóa
☐	Xoay vòng log: xoay, nén, giữ N, xóa cũ hơn	Tất cả	Tự động hóa
☐	Mỗi công cụ: getopts khi hợp lý, --help, ghi log rõ; toàn bộ qua shellcheck	Tất cả	Tự động hóa
Điểm thưởng — tùy chọn (+1 điểm)			
☐	TLS tự ký phục vụ site/app; chuyển hướng HTTP→HTTPS; mở 443	Tất cả	Thưởng
☐	Báo cáo giải thích vì sao không dùng được Let's Encrypt trên VM cô lập	Tất cả	Thưởng

13. Bảng kiểm trước buổi demo

Đánh dấu mọi ô trước khi trình bày. Nếu còn ô trống, hãy khắc phục trước.

Hệ thống & nền tảng

- ☐ Đã đặt hostname; dùng tài khoản sudo non-root; đã tắt đăng nhập SSH bằng root.
- ☐ Vùng dữ liệu/sao lưu tồn tại qua reboot (kiểm tra trong /etc/fstab).
- ☐ Đã dựng đủ ≥ 2 VM và có sơ đồ kết nối.
- ☐ Tường lửa (UFW hoặc firewalld) mặc định chặn vào; chỉ mở cổng cần và có giải thích.
- ☐ fail2ban bảo vệ SSH; ban được kích hoạt trực tiếp.
- ☐ auditd theo dõi /etc/passwd và /etc/shadow; dấu vết đọc được.
- ☐ Đã ghi lần chạy Lynis; khắc phục ba mục.

Ba thành phần của dự án

- ☐ Web server (Nginx/Apache) reverse proxy + ≥ 2 virtual host phản hồi (Thành phần 1).
- ☐ Ứng dụng phục vụ đầu-cuối qua web server; CSDL chỉ nghe localhost (kiểm chứng bằng ss) (Thành phần 2).
- ☐ App chạy như dịch vụ systemd và tự khởi động lại sau khi kill (Thành phần 2).
- ☐ Menu điều phối tới mọi công cụ; deploy có rollback hoạt động (Thành phần 3).

Sao lưu & tự động hóa

- ☐ Sao lưu tự động (cron/timer), có nén, gán nhãn thời gian, có lưu giữ.
- ☐ Đã luyện khôi phục và phục hồi được dữ liệu thật.
- ☐ Script health-check phát hiện lỗi thật và gửi cảnh báo.
- ☐ Mọi script dùng set -euo pipefail + trap và qua shellcheck.

Sản phẩm nộp

- ☐ Báo cáo (PDF) hoàn chỉnh, có bằng chứng cho mọi khẳng định về bảo mật/sao lưu/tự động hóa.
- ☐ Đã tạo file nén: báo cáo + script + file cấu hình thật + README.md, không có bí mật thật.
- ☐ Có bảng phân công 5 thành viên trong README/báo cáo.
- ☐ Đã chụp snapshot trạng thái tốt của VM trước demo.
- ☐ Đã tập demo đầu-cuối trong thời gian quy định.
- ☐ (Điểm thưởng) TLS tự ký hoạt động và lập luận "vì sao không dùng Let's Encrypt" có trong báo cáo.